Ethical-Hacking Engagement Framework for a University's Authorized Security-Assessment Programme

Course: ITA14 Ethical Hacking · **Assignment 1 (CO1)** · **Prepared by:** Ethical-Hacking Governance Team (Name / Reg. No.: Keerthika V)

.

Task 1 – Enquiry and Framework Blueprint

1.1 Scenario converted into governance requirements

Systems in scope (initial ~20 systems, grouped):

Group	Examples (ID prefix)	Data sensitivity
Student portal	Portal web app, SSO, payment gateway link (SYS-SP-*)	High – personal and academic data
Learning-management system	LMS app, DB, file store (SYS-LMS-*)	High – grades, submissions
Email service	Mail gateway, webmail, directory (SYS-MAIL-*)	High – personal communication
Campus network	Core/edge routers, VLANs, Wi-Fi controller, DNS/DHCP (SYS-NET-*)	Medium – infrastructure
Supporting	Admin consoles, jump hosts, monitoring (SYS-SUP-*)	Medium

Stakeholders: Vice-Chancellor/Registrar (ultimate authority) · CISO/IT Director (programme owner) · System owners (department heads) · Data Protection Officer (DPO) · Legal counsel · Internal testers (about 50 staff in scope for the first phase) · External assessors (future) · Students/staff (data principals) · Helpdesk/SOC (detect and respond) · Vendors/hosting providers.

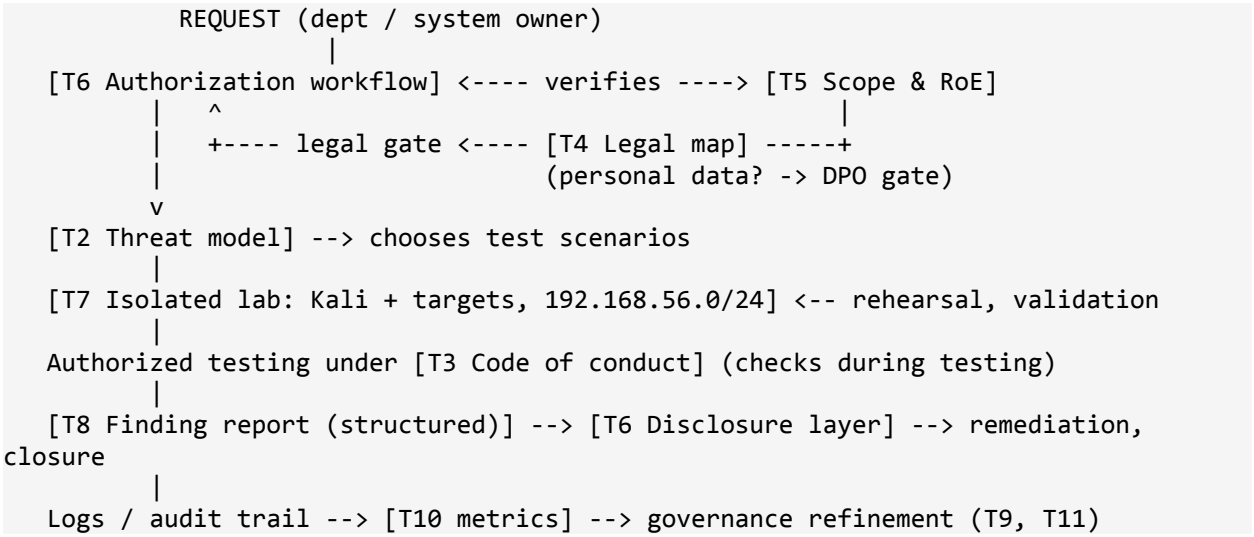
Expected activities: request and approve engagements; define scope; perform reconnaissance, vulnerability assessment and (where authorised) controlled penetration testing; hands-on practice in an isolated lab; report and disclose findings; track remediation; audit.

Constraints: (C1) live systems must not be damaged or made unavailable during term time; (C2) personal data must be protected; (C3) the framework must scale from 20 systems/50 staff to the whole university plus third parties; (C4) laws must be respected (IT Act 2000, DPDP Act 2023, and CFAA where US-linked parties or systems are involved); (C5) no live exploitation in this assignment.

Formal governance requirements

ID	Requirement
GR-01	No test starts without written, verifiable authorization from an authority that owns the target.
GR-02	Every engagement has a written scope: in-scope and out-of-scope assets, with unique identifiers.
GR-03	Rules of Engagement (RoE) define windows, permitted/prohibited techniques and escalation.
GR-04	Every control traces to a legal requirement; personal-data tests trigger extra safeguards.
GR-05	Attacker types are modelled to choose realistic test scenarios (threat-led testing).
GR-06	Testers sign and follow a code of conduct; violations stop the engagement.
GR-07	Hands-on techniques are first practised in an isolated lab, never first on live systems.
GR-08	Findings are reported in a standard format and disclosed through a coordinated process with a timeline.
GR-09	All approvals, changes and disclosures are logged and auditable.
GR-10	The framework must work for external assessors and larger scale without redesign.

1.2 Framework blueprint (how components cooperate)



Rationale: authorization is the gate; scope/RoE are the boundary; law is the constraint on both; the threat model decides *what* to test; the lab decides *where to practise*; the code of conduct governs *how* testers behave; disclosure governs *what happens after* a finding. The structured finding report is the data link back into authorization, scope and legal records.

1.3 Enquiry questions

#	Enquiry question	Answered in
Q1	Who may authorize a test, and how is that authorization proven and recorded?	T5, T6
Q2	What exactly is in scope, and how is an out-of-scope request detected?	T5
Q3	Which laws apply, especially when personal data is touched, and which control satisfies each?	T4
Q4	Which attacker types must the university defend against, and how is an actor classified consistently?	T2
Q5	How are discovered vulnerabilities disclosed, in what time, and when is disclosure allowed to proceed?	T6
Q6	How is hands-on practice kept isolated and authorized?	T7
Q7	Does the framework stay governable when it grows 10× with third-party assessors?	T10, T11

1.4 Design criteria (used as final acceptance criteria)

ID	Criterion	Acceptance test
DC1	**Authorized** – nothing runs without verified sign-off	Test case with missing/expired authorization is blocked (T9 TC-1)
DC2	**Legal** – each legal requirement has ≥1 control	100% of rows in the legal table (T4) have a control ID
DC3	**Bounded** – scope is unambiguous and machine-checkable	Out-of-scope request is detected by allow-list check (T5, T9 TC-2)
DC4	**Safe** – no harm to live systems/data; lab is isolated	Lab has no route to production or the internet (T7 verification)
DC5	**Accountable** – every decision is logged and traceable	Each engagement has a complete audit record (T6 log)
DC6	**Scalable** – approval effort stays proportionate to risk	Large-programme approval wait ≤ 0.5 day (T10)
DC7	**Responsible disclosure** – findings reach owners quickly and are not released prematurely	Timeline defined and enforced (T6)

Task 2 – Hacker Threat Model and Classification

2.1 Classification criteria and naming

An actor is classified on **four attributes, applied in this order** (this ordering is what makes classification consistent):

1. **Authorization (A):** `AUTH` = explicit written permission from the owner; `NONE` = none; `PARTIAL` = permission existed but was exceeded.
2. **Intent (I):** Protect · Gain (financial) · Ideology · Curiosity/ego · Espionage/strategic · Harm/revenge.
3. **Capability (C):** C1 tool-user, C2 skilled individual, C3 organised group, C4 nation-level resources.
4. **Position (P):** `EXT` outsider, `INT` insider (holds legitimate credentials: staff, student, contractor).

Naming code: `<A>-<I>-<C>-<P>`, e.g. `NONE-Gain-C2-EXT`. Class names follow the decision rules in 2.3.

2.2 Threat-model mapping

Type	Authorization	Motivation	Typical capability	Likely university targets
White-hat (ethical hacker)	AUTH	Protect, improve security	C2–C3	Any in-scope system under a signed engagement
Black-hat (cyber-criminal)	NONE	Financial gain	C2–C3	Payment pages, student personal data, ransomware on LMS/servers
Grey-hat	NONE (but benign or ambiguous intent)	Curiosity, reputation, "public good"	C2	Internet-facing portal, LMS, exposed services
Script kiddie	NONE	Fun, bragging, mischief	C1	Defacement or DoS of public web pages, weak passwords, known CVEs
Hacktivist	NONE	Ideology/protest	C1–C3	University website, social media, email leaks tied to controversies
Insider (malicious or negligent)	PARTIAL/NONE	Grievance, gain, or carelessness	C1–C3 + legitimate access	Grades in LMS, staff mailboxes, admin consoles, personal data
State-sponsored (APT)	NONE	Espionage, IP theft	C4	Research data, email, long-term network persistence

Priority for this university (likelihood × impact): Insider and black-hat/ransomware (high), script kiddie and hacktivist (medium frequency, lower impact), state-sponsored (low likelihood but high impact for research units). The test scenarios in engagements are drawn from this ranking.

2.3 Decision rules

1. If `A = AUTH` → **White-hat** (regardless of capability).
2. Else if `P = INT` and the access abused is legitimate-but-misused → **Insider** (add the intent tag).
3. Else if `C = C4` and Intent = Espionage → **State-sponsored**.
4. Else if Intent = Ideology → **Hacktivist**.
5. Else if Intent = Gain/Harm and C ≥ C2 → **Black-hat**.
6. Else if C = C1 and Intent = Curiosity/ego → **Script kiddie**.
7. Else if A = NONE and Intent = Curiosity or public interest, with no harm and with disclosure to the owner → **Grey-hat**.

2.4 Borderline actor – alternative classifications

Actor: A student with a normal LMS login changes a URL parameter, sees another student's marks (an access-control flaw), takes no data, and emails the IT helpdesk the next day.

Option	Classification	Reasoning for	Reasoning against
A	**Insider** (negligent/curious)	Holds legitimate credentials; the flaw was reached from inside the portal	No malicious intent; no data taken; reported voluntarily
B	**White-hat**	Intent is protective; disclosure was prompt	No prior written authorization – by Rule 1 this is disqualifying
C	**Grey-hat**	Unauthorized access beyond entitlement; benign intent; disclosed to owner	Could normalise unauthorized testing if treated leniently

Final classification: Grey-hat (`PARTIAL-Curiosity-C1-INT`) with an *Insider-access flag*. **Justification:** the ordered criteria make authorization the first test, so White-hat is rejected (B). Option A is rejected as the primary class because "insider" implies misuse of entitlement, whereas intent here was benign and the actor stopped and reported. Grey-hat fits Rule 7. The Insider flag keeps the case visible in the insider-risk register. **Governance outcome:** accept the report under the disclosure policy, no punitive action if the safe-harbour conditions (no data copied, no disruption, prompt report) are met, and invite the student to apply for a *authorized* engagement role. This is a policy decision (appropriate for the university), not a legal guarantee of immunity.

Task 3 – Ethics and Code-of-Conduct Module

3.1 Ethical principles

ID	Principle	Meaning in an engagement

P1	Written authorization	No testing without signed, verified permission
P2	Agreed scope	Stay inside the in-scope list, window and techniques
P3	Confidentiality	Findings and any data seen are shared only with named recipients
P4	Integrity	Do not alter, delete or plant data/evidence; keep logs honest
P5	Avoid harm	Prefer non-destructive methods; stop if instability appears
P6	Honest reporting	Report all findings accurately, including tester mistakes
P7	Minimal data handling	Touch the least personal data necessary; never exfiltrate real personal data
P8	Lawfulness and professionalism	Comply with law; declare conflicts of interest

3.2 Rules and checks to detect or prevent unethical actions

Check	Type	Trigger	Action
K1 Authorization-ID gate	Preventive	Any tool run must carry an engagement ID	Block if ID missing/expired
K2 Target allow-list	Preventive	Target IP/hostname not in the signed scope	Block and alert Programme Lead
K3 Time-window check	Preventive	Activity outside the approved window	Pause and log
K4 Technique deny-list	Preventive	Prohibited technique (DoS, social engineering of students, destructive payload)	Block; needs a new approval
K5 Data-touch rule	Detective	Real personal data viewed	Stop, record, notify DPO within the agreed time
K6 Dual log review	Detective	Tester logs and network/SOC logs compared after each session	Mismatch → investigation
K7 Conflict-of-interest declaration	Preventive	Before assignment	Reassign if tester has a personal tie to target
K8 Stop-work rule	Corrective	Any suspected harm or ambiguity	Tester stops and calls the escalation contact

Decision rules: (R1) Any breach of P1 or P2 = **unacceptable** (engagement suspended, review). (R2) Action that is within scope but possibly harmful (P5) = **borderline** (needs approval from the system owner before proceeding). (R3) Action within scope, window and technique list, with logs kept = **acceptable**. (R4) When unsure, classify as borderline and stop (fail-safe).

3.3 Scenario test cases

#	Scenario	Class	Code-of-conduct response
S1	Tester scans only SYS-LMS-01 inside the Tuesday 22:00–02:00 window with a logged tool	Acceptable	Proceed (R3)
S2	Tester finds an open admin page on an in-scope server and records a screenshot with student data masked	Acceptable	Proceed; K5 note if data visible
S3	A weak-password test would lock out 200 student accounts	Borderline	Needs system-owner approval and a throttled/test-account method (R2)
S4	Tester finds a vulnerable server next to the scope that is *probably* university-owned	Borderline	Stop; do not touch; ask owner to extend scope in writing (R4)
S5	Tester overruns the window by 30 min because "the scan was nearly done"	Borderline	Pause (K3); log; justify; retrospective
S6	Tester downloads 500 real student records "as proof"	Unacceptable	Violates P7; stop, notify DPO, incident process, review (R1)
S7	Tester attacks the payment gateway of a third-party vendor not in the authorization	Unacceptable	Violates P1/P2; suspend engagement; legal notified
S8	Tester deletes log entries after causing a service crash	Unacceptable	Violates P4/P6; immediate removal from engagement
S9	Tester demonstrates a vulnerability to a friend outside the team	Unacceptable	Violates P3; confidentiality breach process

Evidence the rules separate the classes: the rules are applied in a fixed order (P1/P2 → P5 → logged compliance). All three *acceptable* cases pass every check K1–K8; the *borderline* cases each trigger exactly one "needs approval" condition; the *unacceptable* cases each violate a hard principle (P1–P4, P7). No case fits two classes, which is the expected consistency result.

3.4 Trust, lawfulness and professionalism

The module preserves trust because **(a)** the university knows exactly what testers may do (K1–K4), **(b)** testers are protected by documented authority and a stop-work right, **(c)** data subjects are protected by P7/K5, and **(d)** independent log comparison (K6) makes honest behaviour verifiable rather than assumed. Lawfulness follows because P1/P2 convert the legal concept of "authorized access" into a technical gate; professionalism follows from declared conflicts, honest reporting and a defined escalation route.

Task 4 – Legal-Compliance Mapping

Note: provisions and penalty figures reflect the Acts as generally understood at the time of writing; verify against the current official text/amendments before final submission.

4.1 Offences, obligations and penalties

Law / section	Offence or obligation	Typical penalty (summary)	Relevance to engagement
IT Act 2000, s.43	Accessing, downloading, introducing malware, disrupting or damaging a computer system **without permission of the owner**	Civil: compensation to the affected person	Core issue: permission of the owner = written authorization
s.66	s.43 acts done *dishonestly or fraudulently*	Up to 3 years imprisonment and/or fine up to 5 lakh	Criminal exposure if testing exceeds permission and intent is wrongful
s.65	Tampering with computer source documents	Up to 3 years and/or fine up to 2 lakh	Do not alter source code/config outside scope
s.66C / 66D	Identity theft; cheating by personation	Up to 3 years and fine up to 1 lakh	Prohibits using stolen credentials or impersonating staff in tests (unless authorized)
s.70	Unauthorized access to a *protected system*	Up to 10 years and fine	Relevant if the university systems are notified as critical
s.72 / 72A	Breach of confidentiality/privacy; disclosure of information in breach of lawful contract	Up to 2 years and/or 1 lakh (s.72); up to 3 years and/or 5 lakh (s.72A)	Testers who see personal data must not disclose it
s.43A (as in force)	Failure of a body corporate to protect sensitive personal data	Compensation to affected persons	University duty to hold data with reasonable security

s.70B and CERT-In directions (2022)	Report specified cyber incidents to CERT-In (generally within 6 hours)	Non-compliance penalised under the Act	Real incidents discovered during testing may need to be reported
DPDP Act 2023 (and Rules)	Data fiduciary must keep reasonable security safeguards, process only for lawful purpose, notify the Board and affected persons of a personal-data breach	Penalties up to 250 crore for failing security safeguards	Testing of systems holding personal data must be minimised and controlled
CFAA, 18 U.S.C. §1030 (US)	Access without authorization or exceeding authorized access; causing damage; trafficking in passwords	Misdemeanour to felony: from up to 1 year up to 10 years (higher for repeat offences) plus civil remedies	Applies if a target, user or server is in the US or if external assessors operate from the US

4.2 Comparison: IT Act vs CFAA

Aspect	IT Act 2000 (India)	CFAA (USA)
Key concept	Without "permission of the owner"	"Without authorization" / "exceeds authorized access"
Civil and criminal split	s.43 civil compensation; s.66 criminal with dishonest/fraudulent intent	Single statute, criminal and civil private action
Role of intent	Needed for the criminal s.66	Knowledge/intent required, varies by sub-section
Good-faith research	No express safe harbour; authorization is the shield	No statutory safe harbour; DOJ policy (2022) says good-faith security research should not normally be charged, but this is a policy, not immunity
Data protection	Separate: s.43A, s.72A, DPDP Act	Not in CFAA; sector laws (FERPA, state privacy laws)

Takeaway: in both systems, *written authorization from someone entitled to give it* is the decisive factor; good intentions alone do not protect a tester.

4.3 Legal requirement → control mapping

Legal requirement	Control in framework	Component

Permission of the owner (s.43; CFAA "authorization")	Signed Authorization Form verified against owner register (AF-01)	T5/T6
Avoid dishonest/fraudulent intent (s.66)	Code of conduct P1–P4; logs K6	T3
No tampering/damage (s.65, s.43)	Technique deny-list K4; non-destructive default in RoE	T3/T5
Confidentiality of data seen (s.72, 72A)	NDA in authorization form; confidentiality clause; encrypted report storage	T6/T8
Reasonable security safeguards and breach duty (s.43A, DPDP)	Data-Protection Gate: DPO approval, data minimisation, masking, stop-and-notify rule K5	T6
Incident reporting (CERT-In)	Escalation path: real incident found → Programme Lead → CISO → CERT-In within required time	T5
Third-party/foreign systems (CFAA)	Scope rule: third-party-hosted assets require the *third party's* written consent and Legal review	T5/T6
Identity/impersonation offences (s.66C/D)	Prohibited technique: no use of real credentials or impersonation without explicit RoE clause	T5

4.4 Which laws apply when a test touches personal data?

Decision: (1) **IT Act s.43/66** always apply (any unauthorized access is an offence regardless of data). (2) **DPDP Act 2023** and **s.43A/72A** are triggered because the university is the data fiduciary and testing is a form of processing/exposure of personal data; therefore the engagement needs the DPO gate. (3) **CERT-In directions** apply if a genuine incident is found. (4) **CFAA** applies only when a US nexus exists (US-hosted asset, US-based assessor, US individuals' systems). **Justification:** applying the stricter combined set to personal-data tests costs little extra process (one DPO sign-off and a data-handling clause), while the legal exposure from under-complying (up to 250 crore under DPDP, criminal liability under s.66) is large.

Task 5 – Scope and Rules-of-Engagement (RoE) Document

5.1 RoE template (reusable)

Document ID: `ROE-<YEAR>-<SEQ>` · **Linked engagement:** `ENG-<YEAR>-<SEQ>` · **Version:** 1.0 · **Status:** Draft / Approved / Expired

A. Naming and boundary conventions

- Every asset has a unique ID: `SYS-<GROUP>-<NN>` (e.g. SYS-LMS-01). Each ID is bound to *name, IP/CIDR, owner, environment (Prod/Test/Lab)* in the **Asset Register**.
- Scope is an **allow-list**: anything not listed is out of scope by default ("deny by default").

- Aliases (CNAMEs, load balancers, CDN addresses) are listed explicitly; a request using an unlisted alias is flagged.

B. In-scope and out-of-scope systems (example engagement ENG-2026-014)

Status	Asset ID	Description	Address	Environment	Owner
In scope	SYS-SP-01	Student portal web app (login, profile pages)	portal.example.edu / 10.20.1.10	Production	Registrar
In scope	SYS-SP-02	Portal staging copy	portal-stg.example.edu / 10.20.9.10	Test	IT Dept
In scope	SYS-LMS-01	LMS app server	lms.example.edu / 10.20.2.10	Production	Academic Affairs
Out of scope	SYS-SP-PAY	Payment gateway (third-party)	pay.vendor.example	Third-party	Vendor – not authorized
Out of scope	SYS-MAIL-*	Email service	10.20.3.0/24	Production	IT Dept (separate engagement)
Out of scope	Any address not in the Asset Register	–	–	–	–
Out of scope	Student/staff personal devices	–	–	–	–

C. Testing windows

Environment	Window	Notes
Lab	Any time	Isolated network only (see Task 7)
Test/Staging	Mon–Fri 09:00–18:00	Notify system owner
Production	Tue/Thu 22:00–02:00 IST, outside exam and admission weeks	Rollback contact on duty; freeze dates published by Registrar

D. Permitted and prohibited techniques

Permitted	Prohibited (unless explicitly added by amendment)

Passive reconnaissance of listed assets	Denial-of-service/stress testing on production
Port and service scanning (rate-limited)	Social engineering of students or staff; phishing
Vulnerability scanning (non-destructive profile)	Destructive payloads, ransomware simulations, data deletion
Authenticated testing with issued **test accounts**	Use of real user credentials; password spraying on real accounts
Manual web testing (injection, access-control checks) with proof-of-concept limited to non-sensitive data	Copying, storing or sharing real personal data
Configuration review	Pivoting beyond scope; testing third-party systems; physical intrusion

E. Escalation path

Event	First contact	Time to respond	Then
System instability or outage	System owner on-call	Immediate (stop testing)	Programme Lead, Helpdesk
Real personal data exposed	Programme Lead + DPO	Within 1 hour	CISO; legal assessment of breach notification
Evidence of a real attacker/active compromise	CISO / SOC	Immediately	CERT-In reporting as required by law
Scope question or ambiguity	Programme Lead	Same working day	Written scope amendment
Critical vulnerability (exploitable, high impact)	CISO	Within 24 hours	Disclosure process (Task 6)

5.2 Authorization-recording and verification rules

1. **Authorization Record (AR)** stores: engagement ID, authorizing person and role, signature (or digital signature/e-sign ID), date, validity period, scope reference, RoE version, tester names, data-protection flag.
2. **Who may authorize:** only the *owner of each asset* listed in the Asset Register (or their delegate recorded in the Delegation Register). Authority cannot be self-granted: a tester or requester cannot approve their own engagement (separation of duties).
3. **Verification steps (V1–V6):** (V1) signature present and identity confirmed through a second channel (call-back or e-sign certificate); (V2) signer is the owner/delegate of *every* in-scope asset; (V3) validity dates cover the planned window; (V4) RoE version matches the AR; (V5) for personal data, DPO sign-off is attached; (V6) for third-party assets, the third party's own written consent is attached.

4. **Failure rule:** if any of V1–V6 fails, status stays *Not Authorized* and the tester's tool-access token is not issued.
5. **Expiry and amendment:** the AR expires at the end date; any change to scope, window or techniques creates a new RoE version and a new AR approval.
6. **Storage:** AR and RoE are kept in a write-once, access-controlled repository for at least the legal retention period set by Legal.

5.3 Detecting an out-of-scope request

Rule: a request is *in scope* only if `target AssetRegister target ScopeList(ENG) time Window technique DenyList`.

Request	Check result
"Scan 10.20.2.10 on Tuesday 23:00 with the vulnerability scanner"	Pass (SYS-LMS-01, in window)
"Also scan 10.20.3.25 (mail server)"	**Fail** – not in ENG scope list; needs amendment
"Test pay.vendor.example login"	**Fail** – third party, no consent (V6)
"Run a password-spray on lms.example.edu"	**Fail** – technique on deny-list; test accounts only

5.4 Transformation: RoE → Pre-engagement checklist

Each RoE clause is converted into a yes/no check that must be ticked before the tool-access token is issued.

#	Check (derived from RoE clause)	Source	Yes / No
1	Authorization Record exists and V1–V6 are all passed	5.2	
2	Every target has a Register ID and matches the IP/hostname in the AR	5.1-A	
3	Out-of-scope list has been read and acknowledged by all testers	5.1-B	
4	Test window is inside the approved window and not in a freeze period	5.1-C	
5	Only permitted techniques selected; deny-list loaded in the tool config	5.1-D	
6	Test accounts issued; no real credentials in use	5.1-D	
7	Escalation contacts verified (phone reachable) and rollback owner on duty	5.1-E	
8	Data-protection flag set; if Yes, DPO sign-off attached and masking rules agreed	T4	

9	Code of conduct signed by each tester; conflicts of interest declared	T3	
10	Lab rehearsal completed and result recorded (for new techniques)	T7	

Rule: all ten answers must be *Yes*. A single *No* blocks the start (fail-closed).

Task 6 – Authorization and Disclosure Layer

6.1 Authorization workflow

Step	Actor	Action	Record created
1. Request	Requester (dept/system owner)	Submits Engagement Request (objective, assets, dates, data flag)	`REQ-id`, status = *Requested*
2. Triage	Programme Lead	Classifies tier (T1 low / T2 production or personal data / T3 external assessor) and drafts scope/RoE	Tier recorded; status = *Triaged*
3. Legal/data check	Legal; DPO (if data flag)	Confirms legal controls (Task 4) and data-protection conditions	Gate result = Pass/Fail
4. Approval	Asset owner(s)	Review RoE, approve or reject	Approval entry per owner
5. Sign-off	CISO (and Registrar for T2/T3)	Written sign-off; AR created and verified (V1–V6)	`AR-id`, status = *Authorized*
6. Token issue	Programme Lead	Issues time-limited tester token tied to ENG-ID	Token log
7. Execution	Testers	Test within RoE; status updates	Status log
8. Close	Programme Lead	Closure, retention of evidence	Status = *Closed*

Approval tiers (used in Task 10): T1 = non-production, no personal data (steps 1, 2, 4, 5, 6 delegated to the department approver). T2 = production or personal data (all steps). T3 = external assessor (all steps + vendor vetting, NDA, background check).

6.2 Responsible (coordinated) disclosure process

Finding report format: ID · title · affected asset ID · severity (CVSS score + business impact) · description · steps to reproduce (sanitised) · evidence (no real personal data) · recommended fix · discoverer · date found · CVE/ref (if any).

Timeline (baseline, 90-day model adapted to the university):

Severity	Initial acknowledgement	Owner fix target	Disclosure decision point
Critical	24 hours	15 days	Day 30
High	2 working days	30 days	Day 60
Medium	5 working days	60 days	Day 90
Low	10 working days	90 days	With next release notes

The *clock starts* when the owner acknowledges the finding report (or on day 3 if there is no acknowledgement, escalated to the CISO). **Extension:** one extension of up to 50% of the window if the owner presents a documented remediation plan.

Comparison of disclosure approaches

Aspect	Coordinated (chosen)	Full disclosure	Bug bounty
Who learns first	Owner, privately	Public at once	Owner via platform; public later
Risk to users in the interim	Low if fixed in time	High (attackers get details before a patch)	Low–medium
Pressure to fix	Timeline-based	Immediate public pressure	Payment incentive
Cost	Low	Low	Ongoing payouts, triage staff
Fit for a university	Best fit now (controlled, accountable, low cost)	Only when owner is unresponsive	Possible future option for public-facing assets after maturity

6.3 Operations for logging and deciding disclosure

Operation 1 – `log_event(engagement_id, event_type, actor, detail)`: appends an immutable entry (timestamp, ID, actor, previous status → new status, approver ID). Valid `event_type`: REQUESTED, TRIAGED, LEGAL_PASS, APPROVED, SIGNED, TOKEN_ISSUED, FINDING_FILED, OWNER_ACK, FIXED, DISCLOSED, CLOSED, BREACH.

Operation 2 – `update_status(finding_id, new_status)`: allowed only along the legal transitions: *New → Acknowledged → Fix-in-progress → Fixed → Verified → Disclosed/Closed*; any other jump is rejected and logged.

Operation 3 – `can_disclose(finding_id)` returns Yes/No with a reason:

```
IF finding.status in {Fixed, Verified}                                    -> YES
(publish advisory with owner's agreement)
ELIF severity's disclosure-decision day reached AND owner was ack'd AND no fix ->
YES, only after CISO + Legal approval (partial/mitigation advisory)
```

```
ELIF personal data involved AND DPDP notification duty not yet met          -> NO
(breach process first)
ELIF affected third party has not been notified                             -> NO
ELSE                                                                        -> NO
(continue timeline)
```

6.4 Rules: coordinated vs full disclosure

Condition	Choice
Owner responsive and fix feasible in the window	**Coordinated**
Vulnerability is internal to one university system	**Coordinated** (no public release unless needed for users)
Vulnerability in third-party/vendor product	**Coordinated with vendor**; follow vendor's policy, shared timeline
Owner unresponsive after two escalations and the window has ended; users at risk	**Limited full disclosure** (mitigation advice, not exploit details), approved by CISO and Legal
Evidence the flaw is being actively exploited	**Immediate notice** to owners and users; CERT-In report; details withheld until fix
Personal data exposed	**Never** full disclosure before DPO/legal breach assessment

6.5 Interaction with RoE (Task 5) and legal compliance (Task 4)

Interaction	Evidence
RoE → Authorization: The AR cannot be issued until the RoE scope IDs match the Asset Register and V1–V6 pass	Workflow step 5 depends on checklist items 1–2
Authorization → RoE: A scope amendment found during testing creates a new RoE version and returns the engagement to step 4	`update_status` rejects testing activity against a superseded RoE
Legal → Authorization: Step 3 (Legal/DPO gate) must pass before approval; failing it ends the workflow	Personal-data flag adds the DPO gate (s.43A, DPDP)
Legal → Disclosure: `can_disclose` refuses release where a breach-notification duty is unresolved	Rule row "personal data exposed"
RoE → Disclosure: A finding is only accepted if its asset ID is in the RoE scope; out-of-scope findings are reported as *incidental findings* under a separate, limited process	Finding report field *Affected asset ID* is validated against scope

Task 7 – Isolated Ethical-Hacking Lab

7.1 Components, roles and connectivity

Component	Role	Interface	Address
Host computer	Runs the hypervisor (VirtualBox/VMware); owner of lab	Host-only adapter (virtual)	192.168.56.1
Kali Linux VM	Tester machine (tools: Nmap, Wireshark, Burp Suite, etc.)	1 × host-only NIC	192.168.56.10
Authorized target 1	Intentionally vulnerable Linux VM (e.g. Metasploitable-type)	1 × host-only NIC	192.168.56.20
Authorized target 2	Replica web/LMS-like VM with *synthetic* data	1 × host-only NIC	192.168.56.30
(Optional) Lab logger	Captures traffic and records snapshots	1 × host-only NIC	192.168.56.40

Network: one host-only network `192.168.56.0/24`, DHCP disabled, static addresses reserved; **no bridged adapter, no NAT adapter** on any VM; host firewall rule blocks forwarding between the host-only adapter and any other interface.

```
  [Kali 192.168.56.10] ---+
  [Target1 192.168.56.20] -+-- Host-only switch (192.168.56.0/24) -- [Host .1]  X (no
route to Internet / campus)
  [Target2 192.168.56.30] -+
  [Logger 192.168.56.40] --+
```

7.2 Recording the lab configuration

A **Lab Configuration Record (LCR)** is saved after setup and after every change: LCR-ID, date, host OS/hypervisor versions, VM names and image hashes (SHA-256), snapshot names, NIC type and MAC, IP address, installed tool versions, purpose of each target, "authorized-by" reference (Lab Policy AF-LAB-01), and operator name. Snapshots are taken in a *clean* state; the lab is restored from the snapshot after each exercise.

7.3 Operations

Operation A – `verify_connectivity()` (run from Kali):

1. `ip addr show` → confirm the interface has `192.168.56.10/24` and *only one* interface exists.
2. `ping -c 3 192.168.56.20` and `192.168.56.30` → expected: replies (lab works).
3. `nmap -sn 192.168.56.0/24` → expected: only the four lab hosts appear.
4. **Isolation check:** `ping -c 2 8.8.8.8` and `ping -c 2 <campus gateway>` → expected: **no reply / network unreachable** (lab contained).

5. Result and timestamp are written into the LCR.

Operation B – `record_lab_setup()`: collects the data in 7.2 (`ip addr`, `uname -a`, tool versions, VM export metadata, hash values) into one text/JSON record and stores it with the engagement ID. If any VM has more than one NIC or an address outside 192.168.56.0/24, status = *Invalid lab* and testing is not permitted.

Operation C – `reset_lab()`: revert all VMs to the clean snapshot, then re-run Operation A.

7.4 Host-only vs NAT

Aspect	Host-only	NAT
VMs reach each other	Yes	Typically no (each VM is behind NAT) unless a NAT network is configured
VMs reach the Internet	**No**	Yes (outbound)
Reachable from the Internet/campus	No	No inbound by default, but outbound traffic is possible
Risk of accidental testing of real systems	**Very low**	Higher: tools can reach real hosts through the NAT
Tool/OS updates	Must be done offline or in a separate step	Easy
Fit for ethical-hacking practice	**Best**	Acceptable only for update windows

Chosen design: host-only network for all practice, with updates performed in a separate maintenance session (temporarily NAT on the Kali VM *before* any target is powered on, then disabled and verified by Operation A). **Justification:** the main risk the framework controls is unauthorized access; removing outbound routes removes that risk by design rather than by tester discipline.

7.5 How the lab keeps testing authorized and contained

- **Authorized by design:** only machines in the LCR with an *authorized-by* reference exist in the lab; every target is built or owned by the university, with synthetic data.
- **Contained by network:** host-only addressing, no gateway, no NAT, host forwarding disabled; the isolation check is mandatory before each session.
- **Controlled by process:** lab sessions require an engagement/rehearsal ID in the log (K1); snapshots allow safe recovery; findings from the lab go into the same finding-report format, but marked *Lab*.
- **Rehearsal rule:** a new technique must be rehearsed in the lab and recorded before it is allowed on a test/production system (checklist item 10).